ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Rockwell Automation PowerFlex 755T (TotalFORCE: 755TL/TM/TR/TS) AC Drive · Component type: **Embedded Device (EDR) - variable frequency drive (VFD), CIP Security-capable** · Target SL = SL 3

Where to work	**CCW / DriveExecutive** or **Studio 5000** drive AOP via **FactoryTalk Linx 6.11+** (required for CIP Security); the **Enhanced HIM** (20-HIM-A6/-C6S); **FactoryTalk Policy Manager + FactoryTalk System Services** (CA) to configure/enroll CIP Security; **ControlFLASH Plus** + PCDC for signed firmware; **FactoryTalk AssetCentre** for audit/DR.
CIP Security	755T has native CIP Security using the **built-in dual EtherNet/IP ports on the Main Control Board** (an option comm card is NOT used for CIP Security). Key feature: **Protection Mode** - when enabled, the drive only accepts CIP-Security-authenticated connections and blocks unauthenticated/tooling access. Port model still applies: drive host = Port 0 (e.g. 0:230 Write Mask, 0:324 Logic Mask).
Notes	EDR - AC drive/VFD, PowerFlex 755T family (TotalFORCE). Confirm firmware rev, the specific model (TL/TM/TR/TS), and whether Protection Mode + CIP Security are actually enabled (capability present does not mean configured). Confirm any integrated-safety/STO option for 3.6.
How to read	Read-only: review the CCW/Studio 5000 parameter set, HIM, and the FactoryTalk Policy Manager CIP Security model. Native how-to (exact param/menu/screen) + external-tool validation + pass. Scans authorized; fuzz ISOLATED lab only with written authorization.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification & auth	Verify layered access: (1) **CIP Security Protection Mode** enabled so only authenticated (certificate-bound) tools/controllers can connect and write - confirm in **FactoryTalk Policy Manager** that the 755T is in the security model with Protection Mode on. (2) **HIM password**: Enhanced HIM › Main Menu › Preferences › HIM Password set non-zero. (3) **Write protection** 0:230 [Write Mask Cfg] (see live state 0:231 [Write Mask Act]). (4) FactoryTalk Security for the AOP. **Test:** connect a non-enrolled tool - Protection Mode must refuse it. **Ext. tools:** FactoryTalk Policy Manager (Protection Mode/model); attempt non-enrolled connect (isolated) - refused.	Protection Mode on; HIM password + Write Mask set; no unauthenticated write.	
SR/CR 1.2	Software process / device identification	Confirm the drive and each comm partner are uniquely identified and, under CIP Security, mutually authenticated by **device certificate**. In CCW/Studio 5000 read the embedded-ENet identity (IP/host name); in Policy Manager confirm the drive's certificate identity. **Ext. tools:** FactoryTalk Policy Manager (cert identity); CCW (IP/name); Wireshark.	Unique, certificate-bound device identity; partners authenticated.	
SR/CR 1.3	Account management	Review FactoryTalk users/roles for the AOP (operate/configure/administer) in the FactoryTalk Administration Console - remove defaults, least privilege; control HIM-password custody; manage CIP Security enrollment membership in Policy Manager. **Ext. tools:** FactoryTalk Admin Console; Policy Manager membership; HIM custody.	Accounts/enrollment managed, least-privilege; defaults changed.	
SR/CR 1.4	Identifier management	Confirm unique FactoryTalk IDs and a unique drive identity (EtherNet/IP address + host name + certificate + serial); no reuse across drives. **Ext. tools:** FactoryTalk; Policy Manager; CCW device info.	Unique user, device, and certificate identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Enforce strong FactoryTalk passwords and a strong HIM code; change all defaults. CIP Security replaces password-only trust with certificate keys - confirm key strength/rotation policy in Policy Manager. **Ext. tools:** FactoryTalk password policy; Policy Manager key/cert policy; HIM review.	Strong managed authenticators + certificate keys; no defaults.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.8	PKI certificates	Confirm the 755T holds a device certificate issued by the asset-owner CA (**FactoryTalk System Services**), valid/not-default, with a managed trust list in **FactoryTalk Policy Manager**. **Ext. tools:** FactoryTalk Policy Manager (certificate status); openssl.	CA-issued device certificate; defaults replaced; trust list managed.	
SR/CR 1.9	Strength of public key auth	Confirm CIP Security uses TLS/DTLS with current cipher suites and strong keys; no weak/expired certs. **Ext. tools:** Wireshark (DTLS/TLS suite); Policy Manager review.	Strong crypto on secured channels.	
SR/CR 1.10	Authenticator feedback	Confirm CCW/Studio 5000 logon, FactoryTalk logon, HIM password entry, and any web login obscure the secret during entry. **Ext. tools:** Visual verification at each interface.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm repeated failed FactoryTalk/web logins are locked/throttled and recorded; monitor failed-auth via AssetCentre/SIEM. HIM code has no lockout - residual noted, mitigated by physical control + Protection Mode. **Ext. tools:** FactoryTalk lockout policy; SIEM failed-auth.	Failed logins locked/throttled/logged; HIM residual noted.	
SR/CR 1.12	System use notification	No native drive banner; enforce the approved use notice on the EWS (GPO) and HMI (compensating). **Ext. tools:** EWS GPO / HMI banner review.	Use notice at EWS/HMI (compensating at drive).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the embedded EtherNet/IP is reachable only from the trusted cell zone behind the cell firewall / Stratix ACLs; remote engineering via VPN; with Protection Mode on, even in-zone tools must authenticate. **Ext. tools:** Nmap (from untrusted side); firewall/ACL review.	Untrusted-network access denied; in-zone access still authenticated.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Verify least-privilege command/config: 0:324 [Logic Mask] restricts which ports may Start/Jog/Direction (Stop never masked); 0:230 [Write Mask] restricts write ports; Protection Mode blocks unauthenticated writes; FactoryTalk Security limits AOP edits. **Test:** from a port whose Logic-Mask bit is clear or an unauthenticated tool, attempt Start/write - must be refused. **Ext. tools:** CCW (0:324 / 0:230); Policy Manager; attempt unauthorized command (isolated).	Logic/Write Mask + Protection Mode + FactoryTalk enforce least privilege.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control the engineering laptop and USB/SD on option modules; removable-media policy on the EWS; only authorized projects loaded. **Ext. tools:** Physical inspection; EWS removable-media policy.	Portable/engineering media controlled.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code; confirm only signed firmware + configured parameters run and web content is vendor read-only. **Ext. tools:** CCW / web review.	Only trusted firmware/config runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm CCW/Studio 5000 sessions time out on inactivity and require re-auth; HIM reverts to non-editing after its timeout. **Ext. tools:** CCW timeout config; HIM timeout behavior.	Sessions lock/timeout on inactivity; re-auth required.	
SR/CR 2.6	Remote session termination	Confirm remote engineering / CIP sessions can be terminated and idle sessions close; enrollment limits who can reconnect. **Ext. tools:** FactoryTalk Linx / connection review; Wireshark.	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm concurrent programming/monitoring connections are bounded and monitored; the CIP connection limit prevents conflicting simultaneous config. **Ext. tools:** CCW/adapter connection review; FactoryTalk Linx.	Concurrent privileged sessions limited/monitored.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.8	Auditable events	Confirm configuration/firmware changes are captured in **FactoryTalk AssetCentre** (Audit + DR) with the acting user; read the drive fault/alarm queue (HIM › Diagnostics › Faults); forward events to the SIEM. TotalFORCE predictive/monitoring data can corroborate. **Ext. tools:** AssetCentre audit; HIM/CCW fault queue; Syslog/SIEM.	Config/firmware changes audited and attributable.	
SR/CR 2.9	Audit storage capacity	The drive fault/alarm queue is finite; rely on AssetCentre/SIEM for retention; confirm sizing and threshold alerting. **Ext. tools:** AssetCentre DB sizing; SIEM retention.	Events offloaded and retained; alert before capacity.	
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/AssetCentre alerts on forwarding/collection failure. **Ext. tools:** SIEM / AssetCentre health alerting.	Audit-failure alerting defined.	
SR/CR 2.11	Timestamps	Confirm the controller/system time source is NTP-synced so AssetCentre/SIEM event timestamps are accurate and correlate. **Ext. tools:** NTP / controller time review.	Reliable, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: the removable HIM (lock cabinet or blank HIM), option-module ports, USB/SD, DPI. Optionally disable HIM Start (750-PM100 local-mask procedure). Disable any unused embedded web service. **Ext. tools:** Physical inspection; CCW (HIM-start / port / web config).	Physical/diagnostic interfaces controlled; unused services disabled.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	Confirm **CIP Security** provides integrity + confidentiality (DTLS/TLS) on the embedded EtherNet/IP between controller and drive, with Protection Mode enforcing it; verify with a capture that channels are secured, not cleartext CIP. **Ext. tools:** Wireshark (secured vs cleartext CIP); Policy Manager.	Comms integrity + confidentiality via CIP Security; Protection Mode enforced.	
SR/EDR 3.2	Protection from malicious code (component)	Confirm only Rockwell-signed firmware runs. 755T firmware ships as signed .dmk; ControlFLASH Plus/the drive validates the signature and rejects unsigned/altered images. **Ext. tools:** ControlFLASH Plus (signature verify); PCDC checksum.	Only signed firmware runs; component protected.	EDR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: Protection Mode/CIP Security state, 0:230 Write Mask, 0:324 Logic Mask, HIM password, web state, access level, against the baseline; CCW compare to the archived project. **Ext. tools:** CCW compare; Policy Manager; Nmap (services off).	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Archive the parameter set / project in AssetCentre; enable change detection; keep Write Mask restrictive and Protection Mode on so unauthorized parameter/firmware change is prevented/detected. Compare online-vs-offline. **Ext. tools:** AssetCentre change detection; CCW online-vs-offline compare.	Config integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Confirm the drive tolerates malformed EtherNet/IP/CIP frames without faulting or unsafe motion. **ISOLATED only:** fuzz the embedded EtherNet/IP on a bench drive and watch the fault queue / connection status. **Ext. tools:** ENIP/CIP fuzzer (ISOLATED); Wireshark.	No crash or unsafe motion on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic output	Verify the fault / comm-loss reaction so the motor reaches a defined safe state: set the embedded-ENet **Comm Flt Action** and **Idle Flt Action** and the drive **Fault Config** to Fault/Stop as designed; where an integrated-safety/STO option is fitted, function-test torque removal. **Ext. tools:** CCW (Comm/Idle Flt Action + Fault Config); STO/safety function test (lab).	Drive assumes a defined/safe state (STO) on fault or comm loss.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.7	Error handling	Confirm graceful fault handling: fault/alarm queue, defined fault actions, auto-restart disabled unless justified; no unsafe restart. **Ext. tools:** CCW/HIM (fault queue + fault actions; auto-restart config).	Graceful fault handling; no unsafe restart or info leak.	
SR/CR 3.8	Session integrity	With CIP Security, sessions are integrity-protected against replay/hijack; confirm secured channels in use (Protection Mode) and no unauthenticated session path remains. **Ext. tools:** Wireshark (session inspection); Policy Manager.	Sessions integrity-protected; no unauthenticated path.	
SR/CR 3.9	Protection of audit information	Protect the AssetCentre audit DB and Syslog transport; restrict who can read/clear the drive fault queue and change records. **Ext. tools:** AssetCentre DB access review; SIEM access review.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Update firmware only with Rockwell-signed .dmk via **ControlFLASH Plus** (signature validated); plan the update in a maintenance window with rollback to the prior signed revision; cross-check against PCDC. **Ext. tools:** ControlFLASH Plus (signed update/verify); PCDC checksum.	Signed firmware updates only, with a controlled update + rollback path.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Keep the drive in a locked, sealed cabinet; control the HIM and option-module/USB/SD; AssetCentre audit + fault queue record config/firmware changes as tamper evidence. **Ext. tools:** Physical inspection; AssetCentre / fault-queue review.	Cabinet locked/sealed; interfaces controlled; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	The drive accepts only Rockwell-signed firmware (supplier root of trust); confirm the signing chain is intact and unsigned/altered .dmk is rejected at load. **Ext. tools:** ControlFLASH Plus (verify); attempt unsigned image (isolated) -> rejected.	Supplier signing root intact; unsigned/altered firmware rejected.	EDR-specific.
EDR 3.13	Provisioning asset-owner roots of trust	Confirm the asset owner's **FactoryTalk System Services** is the CA and the 755T is enrolled with its certificate managed in **FactoryTalk Policy Manager** (asset-owner root of trust for CIP Security). **Ext. tools:** FactoryTalk Policy Manager / System Services (CA + enrollment).	Asset-owner certificate provisioning verified.	EDR-specific.
EDR 3.14	Integrity of the boot process	Confirm the drive validates signed-firmware integrity before execution; no unsigned/tampered firmware runs. Capture the firmware revision + signed status (HIM › Diagnostics › Version, or CCW device info). **Ext. tools:** CCW/HIM (firmware revision/signed status); ControlFLASH Plus.	Firmware integrity validated before execution; only signed firmware boots.	EDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, reset the drive to defaults (0:8 [Reset To Defalts] / Set Defaults) and clear option-module config + CIP Security enrollment/certificates; sanitize/destroy any SD so configuration and keys are not recoverable. **Ext. tools:** CCW/HIM (Set Defaults); Policy Manager (remove enrollment); media sanitize.	Config + certificates purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	Confirm CIP Security uses modern crypto (TLS/DTLS, strong suites); disable any legacy unauthenticated web/service; certificates/keys managed in FactoryTalk. **Ext. tools:** Wireshark / testssl.sh; Policy Manager review.	Modern crypto in use; legacy services disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	Confirm the drive sits in a controlled cell/zone behind a firewall / Stratix ACLs / SCALANCE; only required EtherNet/IP flows cross the boundary; CIP Security + segmentation are defense-in-depth (not either/or). **Ext. tools:** Nmap by zone; firewall/ACL rule review.	Drive in a segmented zone; only required flows cross the boundary.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Single-purpose embedded drive with no general-purpose person-to-person communications. **Ext. tools:** Confirm no such services on the drive.	N/A - justification recorded (single-purpose embedded device).	N/A
SR 5.4	Application partitioning	**N/A.** Single-purpose drive; no separable applications to partition. **Ext. tools:** Confirm single-function device.	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm drive faults/alarms (HIM/CCW) and AssetCentre change records are readable/exportable and forwarded to the SIEM; the cell is passively monitored (OT IDS on a mirror port). **Ext. tools:** AssetCentre export; passive OT IDS (mirror port).	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: the drive CIP connection limits plus cell-firewall rate-limiting prevent a flood from denying control; CIP Security drops unauthenticated floods early. Monitor connection load while testing. **Ext. tools:** Adapter connection review; traffic generator (ISOLATED).	Resources bounded; drive control continues under load.	
SR/CR 7.2	Resource management	Confirm the drive/embedded adapter bounds resource use (max CIP connections, comms load) so a single service cannot starve control. **Ext. tools:** Adapter connection/limits review.	Resources bounded; no exhaustion-based loss of control.	
SR/CR 7.3	Control system backup	Confirm the parameter set / project and option-module config are backed up (AssetCentre DR, versioned, offline) and a restore is tested for a known-good rebuild (including CIP Security re-enrollment). **Ext. tools:** AssetCentre DR review; restore test (lab).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Confirm hardening: Protection Mode on, disable any unused embedded web service, disable unused option-module functions/ports, set 0:230 Write Mask / 0:324 Logic Mask restrictively, HIM password set. **Ext. tools:** CCW (masks / services); Policy Manager (Protection Mode); Nmap.	Least functionality; unused services disabled per baseline.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm the drive (catalog, firmware rev, option modules, embedded adapter) is inventoried so vulnerabilities track against Rockwell Automation security advisories. **Ext. tools:** CCW/AssetCentre inventory; ReadOnlyEnum.	Accurate component/firmware inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
CCW / DriveExecutive / Studio 5000	Native config & protection review (all FRs)	Read parameters (0:230 Write Mask, 0:324 Logic Mask, fault/comm-loss actions, firmware rev) and safety config; compare to baseline.	Read/authorized project copy.
Enhanced HIM (20-HIM-A6/-C6S)	On-drive review (1.1, 2.13, 3.14)	Confirm the HIM password, access level, fault queue, and firmware version at the panel.	Physical; authorized.
FactoryTalk Policy Manager / System Services	CIP Security model, CA & Protection Mode (1.1, 1.8, 3.1, 3.13)	Confirm the 755T is enrolled, certificate valid, Protection Mode on, trust list managed.	Read-only.
FactoryTalk Security / Admin Console	Identity & authorization for the AOP (FR1, 2.1)	Read FactoryTalk users/roles; least-privilege check.	Read-only.
FactoryTalk AssetCentre	Audit, change detection & DR (2.8, 3.4, 6.x, 7.3)	Audit config/firmware changes; versioned backup/restore.	Non-intrusive.
ControlFLASH Plus / PCDC	Signed firmware update & verify (3.2, 3.10, 3.12, 3.14)	Verify the drive accepts only Rockwell-signed .dmk; cross-check PCDC checksums.	Maintenance window.
Nmap / Wireshark	Exposed-service, zone & secured-comms review (1.13, 3.1, 5.x, 7.6)	Enumerate EtherNet/IP per zone; confirm CIP Security channels (DTLS/TLS) and Protection Mode behavior.	Read-only/passive; authorized.
ENIP/CIP fuzzer / traffic generator	Input validation & DoS resilience (3.5, 7.1)	Malformed-frame / high-rate EtherNet/IP testing on a bench drive while watching fault queue / connection health.	ISOLATED/non-production; written authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.